

NPC Submission Completeness Audit — Setnayan

Date: 2026-07-16

Scope: Completeness / coverage audit of Setnayan's NPC (National Privacy Commission) submission set against RA 10173 (Data Privacy Act of 2012), its IRR, and relevant NPC Circulars/Advisories.

Prepared for: Owner (PIC) + DPO (Indalecio S. Casasola II) + external PH counsel.

Nature: This is a document-coverage audit, **not legal advice**. "REQUIREMENT" statements describe what the NPC framework generally expects; they are not verified findings about the filing. "COVERED" claims are each grounded in a file + section actually read.

1. Summary verdict

Headline completeness: ~60% filing-ready.

The set is **broad but not adopted**. Measured two ways:

- **Document-existence coverage: ~90%.** Every one of the NPC "five pillars" has at least one dedicated, well-reasoned document. The drafting quality is high and the RoPA/DPIA depth is unusually good for a 2-person sole proprietorship.
- **Content-complete-and-filing-ready coverage: ~55–60%. Nothing is signed, dated, or adopted** — every document carries a DRAFT header and unsigned signature blocks. Several NPC-expected artifacts are entirely absent (executed DPAs/SCCs, NPCRS registration confirmation, LIAs, several HIGH-risk DPIAs, consent-form/notice copies). The set also contains **internal contradictions** that would weaken a filing if lodged as-is, and it documents **live-in-production processing running ahead of both disclosure and counsel review**.

The five headline gaps (in priority order)

1. **Nothing is adopted.** All 13 documents are DRAFT with blank signature/effectivity blocks. There is no signed DPO designation-with-acceptance and no adopted Privacy Manual — the two things the NPC expects to see executed.
2. **No executed sub-processor DPAs / SCCs on file.** Every "DPA on file" cell is [confirm] (doc 07 §5; Manual §8.2). The cross-border transfer basis is *asserted* ("bound by SCCs or equivalent") but not evidenced anywhere in the set.
3. **NPCRS Data Processing System registration is not yet filed / no confirmation attached.** The DPO's contact was registered on the NPC DPO system (2026-07-07, doc 07 §2), but the *Data Processing System* registration (doc 03 Part B is the data sheet only) is unfiled, and no NPCRS acknowledgment/printout is in the set.
4. **Live undisclosed / under-declared processing.** The Anti-Fraud engine shipped to prod 2026-07-07 ahead of counsel and *without* the required disclosure + LIA (doc 08 §6). The reconciliation (2026-07-13) flags religion/civil-status/gender, minors' data (dependents, signature_details), and e-gift handles as **collected in production with disclosure gaps**. Several HIGH-risk DPIAs (vendor ID = R-03, minors = R-05) are **not written**.
5. **Two "canonical" documents disagree with each other.** The executive dossier (2026-07-12/13) **under-declares SPI** relative to the deeper NPC pack (drops vendor gov-ID + AMLC/PEP), and splits on **DPO email** (dpo@setnayan.com vs iscasasolaii@gmail.com) and **DSR response SLA** (15 vs 7 business days). Filing the dossier as-is would under-declare.

Bottom line: This is a strong *drafting* effort that is **not yet a filing**. The path from here is adoption (sign + date), execution of the missing evidentiary artifacts (DPAs, LIAs, the outstanding DPIAs), reconciliation of the internal conflicts, and closing the live-processing disclosure gaps — all under external counsel review, which every document itself names as the gating step.

2. Coverage matrix — RA 10173 / IRR / NPC requirements

Legend: **COVERED** = a document addresses it with substantive content (file + section cited). **PARTIAL** = present but incomplete, unadopted, or with named [TO CONFIRM]/[confirm] holes. **GAP** = not present in the set.

2a. The NPC "Five Pillars of Compliance"

#	Pillar (NPC requirement)	Status	Where covered / what's missing
(a)	Appoint a DPO (RA 10173 §21; NPC Advisory 2017-01)	PARTIAL	Designation record present — 03_DPO_Designation..._2026-07-05.r Part A (appointment, duties per Advisory 2017-01, independence/conflict note, publication contacts). DPO contact registered on NPC DPO system 2026-07-07 (07_Compliance_Facts_Register.md §2). Missing: signatures + effectivity date (both blank/[TO CONFIRM]); DPO title/employment basis [TO CONFIRM]; the PIC=DPO conflict-of-interest independence rationale is drafted but not counsel-confirmed.
(b)	Conduct a PIA/DPIA (NPC Advisory 2017-03)	PARTIAL	DPIA framework + register present — 05_DPIA_Register... indexes 8 systems (R-01...R-08). Complete: R-02 Person Graph (doc 05 Part 2, signed-off block blank). Drafted, unsigned: R-01 Face Vectors (06_...), R-08 Anti-Fraud (08_...). GAP (not written): R-03 Vendor Verification (HIGH — gov-ID + liveness + AMLC), R-04 Payments, R-05 Minors/Legacy (HIGH), R-06 Contract Intelligence, R-07 Chat. Manual §10 states the DPIA duty.

(c)	Privacy Management Program / Privacy Manual (NPC Advisory 2017-01; IRR)	PARTIAL	Flagship manual present — 01_Privacy_Manual_DRAFT_2026-07-07 (12 sections: scope, definitions, governance, principles, lifecycle, 8 DSR rights, consent, sub-processors/cross-border, breach, DPIA, complaints, versioning). Missing: adoption — DRAFT, unsigned, review-cadence "effective on adoption"; multiple [TO CONFIRM] facts (headcount, address, NPC reg no.).
(d)	Privacy & security measures — organizational / physical / technical (IRR Rule VI)	COVERED	Manual §3.2 (all three categories, technical control table); 04_Data_Breach... §3 (controls in place); dossier §8. Strong: RLS deny-by-default, AES-256 at rest, TLS 1.3, signed URLs, two-admin gate, TOTP-for-admins, append-only audit log. Minor [TO CONFIRM] on NDAs/training/device policy (org-measure evidence).
(e1)	NPC registration of the Data Processing System (NPCRS) (NPC Circular 17-01)	PARTIAL	Registration data sheet prepared — 03_... Part B (field-by-field) + threshold analysis (doc 03 §B.0 and 02_RoPA... §2: triggers #1/#3/#4 met). DPO-side registration done 2026-07-07. Missing: the actual DPS filing and any NPCRS confirmation / registration-number printout ; BIR Form 2303/TIN needed for the form is redacted-and-held (doc 07 §1).

(e2)	Breach notification & management (RA 10173 §20; NPC Circular 16-03)	COVERED	04_Data_Breach_Management_Policy_L — DBRT, 72-hour rule, notifiability 3-part test, NPC + data-subject notification content, containment/eradication/recovery, evidence preservation, breach register template, annual NPC report commitment, quick-flow. Strong and Circular-16-03-aligned. Note: DRAFT/unsigned; DBRT contacts + hotline [TO CONFIRM]; breach register is an empty template (expected pre-incident).
------	--	----------------	---

2b. Other RA 10173 / IRR expectations

Requirement	Status	Where covered / what's missing
Public Privacy Notice (transparency; §16 right to be informed)	PARTIAL	A live notice exists at setnayan.com/privacy (dossier §1, effective 2026-05-13, last updated 2026-07-13 via PR #3215). But the notice itself is not a document in this set (the binding 01_Contracts/Setnayan_Privacy_and_Security... is a companion, not included), and the reconciliation (2026-07-13 §A) flags live-notice disclosure gaps (faith/minors/e-gift/device-fingerprint) and a biometric denial that is a landmine once the face model ships.
Records of Processing Activities (RoPA/ROPA)	COVERED	02_Records_of_Processing_Activities... — 12 Data Processing Systems (DPS-01...DPS-12) with purpose, legal basis (§12/§13 mapped), data subjects, categories, sub-processors, cross-border, retention, security, risk level. Also mirrored/summarized in dossier §3 (18 data categories). Caveat: the two RoPAs are not identical in scope — reconcile before filing (see §5).

Consent mechanisms & records	PARTIAL	Mechanisms described — Manual §7 (registration policy_acceptances w/ timestamp+IP+UA; explicit biometric opt-in default-OFF verified in code per doc 06 correction; per-field *_consent_at stamps per dossier §3). Missing: copies/templates of the actual consent strings & notices; the signature_details honoree SPI path collects without a consent timestamp (dossier §11.6, reconciliation §C.2); cookie consent is localStorage-only with no server-side consent-event log (reconciliation §B), weakening proof-of-consent.
Data Sharing Agreements (DSA)	GAP	No DSA is present. (May be genuinely N/A — sharing is to processors, not co-controllers — but the AMLC/DTI/screening flows should be assessed by counsel for whether any constitutes data sharing vs outsourcing.)
Outsourcing / sub-processor (Data Processing) Agreements — DPAs	GAP (evidence)	Sub-processor inventory is present and good (Manual §8.2; doc 03 §B.8; doc 07 §5; dossier §7). But no executed DPA/SCC is on file — every "DPA on file" is [confirm]. This is the single biggest evidentiary hole.
Retention schedule	COVERED (draft)	Data_Retention_Schedule_2026-07-11.md — per-class periods, RA 10173 storage-limit maximum vs BIR RR 17-2013 / Civil Code Art. 1144 minimums, erasure carve-out. [PENDING COUNSEL]; enforcement is greenfield (§4: R2 lifecycle unconfigured, account hard-delete leaves chat PII).
Data-subject-rights (DSR) procedures (§16)	COVERED	Manual §6 (all 8 rights + how-to-exercise + response windows); dossier §6 (self-service export iteration 0025, erasure w/ legal-hold carve-out, objection/withdrawal, complaints to DPO). Conflict: SLA 7 days (Manual §6) vs 15 days (dossier §6) — reconcile.
Cross-border transfer basis (§21)	PARTIAL	Transfers mapped with jurisdictions + claimed bases — Manual §8; doc 03 §B.8; dossier §7 (SG + multiple US processors). Basis asserted as "SCCs or equivalent DPAs" but not evidenced (ties to the DPA gap above). Several jurisdictions [TO CONFIRM] in the pack though resolved in doc 07 §5 (Resend/PostHog/Vercel = US).

Automated decision-making rights (§16(c) / §34)	PARTIAL	Identified and assessed — doc 03 §B.5; doc 08 (Anti-Fraud auto-suspend = reversible automated decision w/ significant effect). Missing: a formal, documented contest/appeal procedure (only a help-center "ticket stub" exists — doc 08 §6, AF-5).
Legitimate Interest Assessment (LIA)	GAP	Two §12(f) processings rely on legitimate interest — Anti-Fraud (doc 08 §1.3) and Device-Fingerprint (dossier §4.3; one-pager). Both require a documented LIA/balancing , and both flag that it does not yet exist (doc 08 §6; one-pager item 1).
Threshold / eligibility analysis for registration	COVERED	02_RoPA. . . §2 + doc 03 §B.0 — Circular 17-01 disjunctive triggers assessed; #3 (risk to rights) + #4 (not occasional) met, #1 (SPI ≥1,000) likely-once-counts-confirmed.
Scale-of-processing figures (NPCRS fields)	COVERED	07_Compliance_Facts_Register.md §3 resolves the [TO CONFIRM] counts from live DB: 19 customers, 50 vendors, 332 guests, 61 events, 0 active biometric vectors (early/pre-launch).

3. Missing documents / artifacts the NPC would expect (not in this set)

Ordered by filing impact.

1. **Signed & dated DPO Designation with the DPO's written acceptance.** Doc 03 Part A is a template with blank signatures + [TO CONFIRM] effectivity date. (*REQUIREMENT: NPC Advisory 2017-01 expects a designation the DPO has accepted.*)
2. **NPCRS registration confirmation / acknowledgment / registration number** (PIC + DPS). The DPO-system registration (2026-07-07) is noted, but no certificate/printout is in the set, and the DPS registration appears unfilled.
3. **Executed Data Processing Agreements / SCCs with each named sub-processor** (Supabase, Vercel, Cloudflare, Resend, Sentry, PostHog, Anthropic, Persona, Google, TikTok, Suno). Currently only an inventory with [confirm] DPA columns.
4. **Standalone/adopted Privacy Notice document** as filed evidence — plus reconciliation of the live setnayan.com/privacy page to the as-built processing (close faith/minors/e-gift/device-fingerprint gaps; fix the biometric "we do not collect" denial).
5. **Consent form / notice templates & copies** — the actual just-in-time consent strings (biometric opt-in, dependents/guardian consent, vendor verification itemized consent, marketing opt-in) and the `signature_details` honoree-SPI consent that currently has **no timestamp**.
6. **Legitimate Interest Assessments (LIAs)** for Anti-Fraud (R-08) and Device-Fingerprint — both are named as required and not yet written.
7. **The outstanding DPIAs:** R-03 Vendor Verification (**HIGH** — gov-ID/liveness/AMLC/PEP, and processing is *live*), R-05 Minors & Legacy (**HIGH**, counsel-first *before* build), R-04 Payments, R-06 Contract Intelligence, R-07 Chat.

8. **Formal automated-decision contest/appeal procedure** (§16(c)/§34) for the Anti-Fraud auto-suspension — elevate the ticket stub to a documented process.
9. **Personnel confidentiality undertakings (NDAs) + privacy-training records + device/endpoint policy** — org-measure evidence ([TO CONFIRM] in Manual §3.2.1, doc 07 §6).
10. **Populated breach register + annual NPC breach summary + table-top drill record** — templates exist (doc 04 §10, §8.2); the operational records do not (acceptable pre-incident, but the drill/annual-report cadence should be initiated).
11. **BIR Form 2303 / Certificate of Registration** — needed for the NPCRS PIC fields (TIN correctly redacted from the repo per doc 07, held in admin → Compliance).
12. **Adopted/signed versions of the Privacy Manual, Breach Policy, and all three completed DPIAs** — all currently DRAFT.
13. **Published Privacy Policy amendments** for Person-Graph and Anti-Fraud (both drafted, neither published — Manual/dossier note publication gated on sign-off).

4. Issues that would block or weaken an actual NPC filing

Blocking (should be resolved before lodging):

- **B1 — Everything is DRAFT/unsigned/undated.** No adopted governance instruments; the filing has no executed backbone.
- **B2 — Live processing ahead of disclosure + counsel.** Anti-Fraud (identity clustering + automated vendor suspension) shipped to prod 2026-07-07 with **no notice, no LIA, no counsel review** (doc 08 status banner + §6). Filing while a known, undisclosed automated-decision processing runs is a material exposure.
- **B3 — In-production SPI/minors collection with disclosure gaps.** Reconciliation (2026-07-13 §A, SEV-1): religion/civil-status/gender live (no flag), `dependents` minors' data reportedly flag-ON in prod, `events.signature_details` collects a child's DOB/gender + pregnancy due-date **with no flag and no consent stamp**, e-gift financial handles undocumented in all 9 privacy docs.
- **B4 — The executive dossier under-declares SPI.** Dossier §5 names only biometric vectors as the registration-triggering SPI and **drops the vendor gov-ID + AMLC/PEP surface** that the NPC pack treats as the trigger (reconciliation §B). Filing the dossier as the backbone would under-declare.
- **B5 — Missing executed DPAs/SCCs** undercut the cross-border-transfer lawful basis (§21).

Weakening (fix to avoid inconsistency findings):

- **W1 — DPO contact split:** `dpo@setnayan.com` (dossier) vs `iscasasolaii@gmail.com` (every other doc). Two published DPO addresses.
- **W2 — DSR response SLA split:** 15 business days (dossier) vs 7 (Manual §6, doc 03).
- **W3 — Device-fingerprint "live vs off" contradiction** across docs (dossier §4 / one-pager say flag-OFF; the Anti-Fraud policy amendment + DPO Designation B.5 say "live 2026-07-07"). Reconcile before either publishes.
- **W4 — Binding Privacy & Security Policy is stale** vs the new retention schedule (no 10-year floor; vendor-verification retention class present in policy but absent from the new schedule + dossier RoPA).
- **W5 — Retention enforcement is greenfield** (R2 lifecycle unconfigured; account hard-delete leaves chat-message PII — Retention Schedule §4). A storage-limitation claim the platform cannot yet enforce.
- **W6 — Durability risk:** the three most-relied-on docs (dossier 07-12, retention schedule 07-11, fingerprint one-pager 07-12) are **untracked/uncommitted** (reconciliation §B) — the "canonical" master is the least durable file.

- **W7 — Two RoPAs of differing scope** (11–12-system pack RoPA vs 18-category dossier RoPA) must be reconciled to one authoritative version.

5. Prioritized "before filing" checklist

Tier 0 — engage counsel + freeze the story (do first):

1. Route the whole set to external PH counsel (every doc names this as the gating step). Specific asks: the §3(l)/minors cluster, the vendor AMLC/PEP + gov-ID basis, the NPC registration threshold, and the automated-decision provisions.
2. Pick **one** authoritative backbone. Recommend the tracked NPC_Compliance/ pack as the filing backbone and demote the dossier to an executive summary — then make the dossier's SPI declaration match the pack (restore vendor gov-ID + AMLC/PEP).
3. Reconcile the conflicts: one DPO email, one DSR SLA, one RoPA scope, one device-fingerprint live/off state. Commit the untracked canonical docs.

Tier 1 — close the live-processing exposure:

4. Publish the **Anti-Fraud** disclosure + record its **LIA** + document a formal §16(c)/§34 contest path (doc 08 §6).
5. Publish the **faith / minors / e-gift / device-fingerprint** disclosures on the public notice and add the matching RoPA rows; **fix the biometric denial** wording.
6. Gate or consent-instrument the `events.signature_details` honoree SPI (child DOB/gender, pregnancy due-date) — currently unflagged, unconsented.
7. Confirm the true prod flag state of `NEXT_PUBLIC_DEPENDENT_PEOPLE` and `PABUYA_PUBLIC_ROUTE_ENABLED`; if ON, add live SPI+minors and financial-PI processing activities.

Tier 2 — execute the missing artifacts:

8. Obtain/execute **DPAs or SCCs** for every sub-processor; attach copies (or record the executed reference) against the inventory.
9. Write the outstanding **DPIAs**: R-03 Vendor Verification (HIGH, live) and R-05 Minors/Legacy (HIGH, counsel-first before any build); decide R-04/R-06/R-07 (standalone vs folded).
10. Record the **Device-Fingerprint LIA** and get the DPO sign-off before flipping the flag (one-pager items 1–4).
11. Adopt the light **NDA / privacy-training / device-hygiene** notes for the 2-person team (doc 07 §6).

Tier 3 — adopt & file:

12. **Sign + date** the DPO Designation (with DPO acceptance), the Privacy Manual, the Breach Policy, and the three completed DPIAs; set effectivity dates.
13. Resolve remaining `[TO CONFIRM]` NPCRS fields (business address granularity, DPO title/phone, BIR TIN from the admin Compliance page) and **file the Data Processing System registration** via NPCRS; **attach the confirmation/registration number** to the set.
14. Reconcile the binding Privacy & Security Policy §4 retention (add 10-year floor + vendor-verification class) and stand up the retention **enforcement** (R2 lifecycle, retention sweep, fix the chat-PII hard-delete residue).
15. Initiate the operational breach-management records (register live, first table-top drill, annual-report cadence).

Prepared as a completeness/coverage audit only. Every "COVERED" is cited to a file + section read on 2026-07-16. "REQUIREMENT" statements reflect the general NPC/RA 10173 framework and must be confirmed by external Philippine counsel, who — per the set's own documents — is the gating reviewer before any NPC lodgment.